Vulnerability Scanning Techniques

Objective:

Configure and validate scan results for accurate risk assessment.

Tools Required:

- **VirtualBox**
- **Kali Linux**
- **Metasploitable**
- **Nmap**
- **Nikto**
- **OpenVAS**

Definitions:

Metasploitable:

It is a vulnerable Linux machine created on purpose to perform various scans and tests to gain hands on experience on real life threats acuting a system.

Nmap:

This is a scanning tool used by experts, professionals, etc. to probe a system to identify and collect various kinds of information like open ports, running services with version, OS in use, any vulnerability if it exists, etc.

Nikto:

A web server vulnerability scanner used in penetration testing to identify security issues in web servers and applications.

OpenVAS:

OpenVAS is a vulnerability assessment tool which is used to scan systems, applications and networks to identify vulnerabilities in them. It also helps create a report of the scan and provide recommendations for remediation.

Steps Performed:

1. **Update and upgrade the kali to its latest version. Also power on the Metasploitable machine. Scan the network using 'nmap' command to identify the metasploitable's IP:**

2. **Three Nmap scans were performed on the target's IP i.e. 192.168.31.242 to scan and gather more details on it:**
   - **Nmap 192.168.31.242 → Basic scan**
   - **Nmap -O 192.168.31.242 → To detect OS running on the target**
   - **Nmap -sC -sV -p- 192.168.31.242 > nmap_scan.txt → To scan all ports of the system using available scripts along with version detection. Then output the scan result to a file named nmap_scan.txt.**

```
┌──(kali㉿kali)-[~]
└─$ nmap 192.168.31.242
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-23 06:20 -0400
Nmap scan report for 192.168.31.242
Host is up (0.0010s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:8E:5B:FA (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.88 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -O 192.168.31.242
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-23 10:15 -0400
Nmap scan report for 192.168.31.242
Host is up (0.0014s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
23/tcp   open  telnet
25/tcp   open  smtp
53/tcp   open  domain
80/tcp   open  http
111/tcp  open  rpcbind
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
512/tcp  open  exec
513/tcp  open  login
514/tcp  open  shell
1099/tcp open  rmiregistry
1524/tcp open  ingreslock
2049/tcp open  nfs
2121/tcp open  ccproxy-ftp
3306/tcp open  mysql
5432/tcp open  postgresql
5900/tcp open  vnc
6000/tcp open  X11
6667/tcp open  irc
8009/tcp open  ajp13
8180/tcp open  unknown
MAC Address: 08:00:27:8E:5B:FA (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
```

```
┌──(kali㉿kali)-[~]
└─$ nmap -sC -sV -p- 192.168.31.242 > nmap_scan.txt

┌──(kali㉿kali)-[~]
└─$ cat nmap_scan.txt
Starting Nmap 7.98 ( https://nmap.org ) at 2026-03-23 06:32 -0400
Nmap scan report for 192.168.31.242
Host is up (0.0013s latency).
Not shown: 65505 closed tcp ports (reset)
PORT      STATE SERVICE     VERSION
21/tcp    open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.31.88
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet      Linux telnetd
25/tcp    open  smtp        Postfix smtpd
| sslv2:
|   SSLv2 supported
|   ciphers:
```

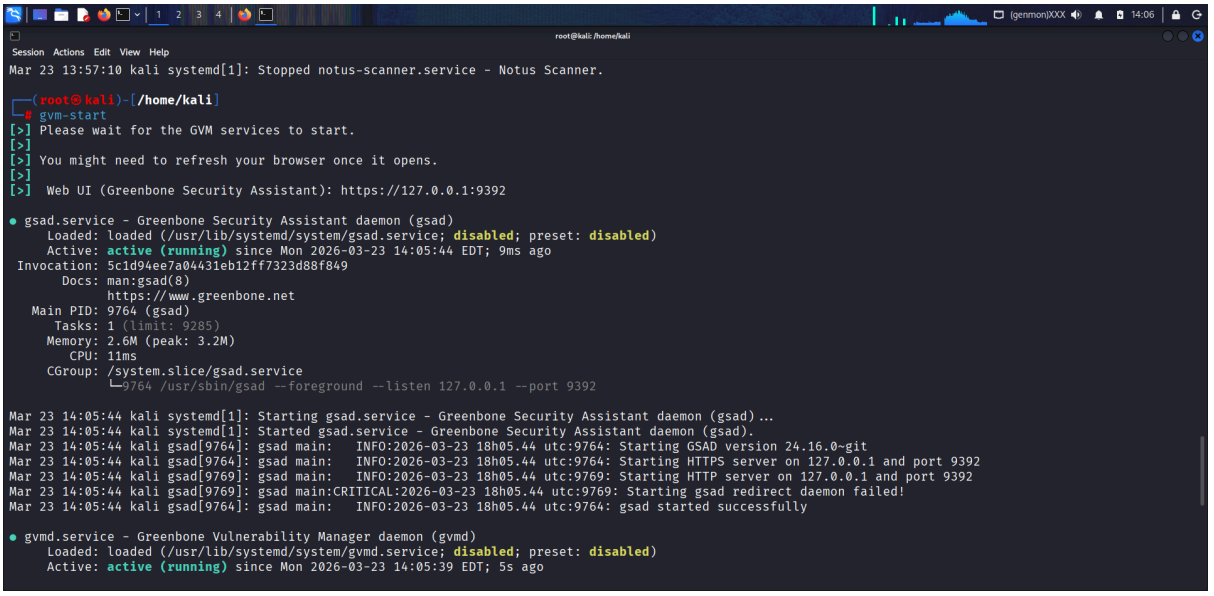
3. **The result of the scan is provided in the following link:** https://drive.google.com/file/d/18RXAFlqQZWv_5lVyZA8TAnCa7ZcBgqHm/view?usp=drive_link
4. **Output of the result:**

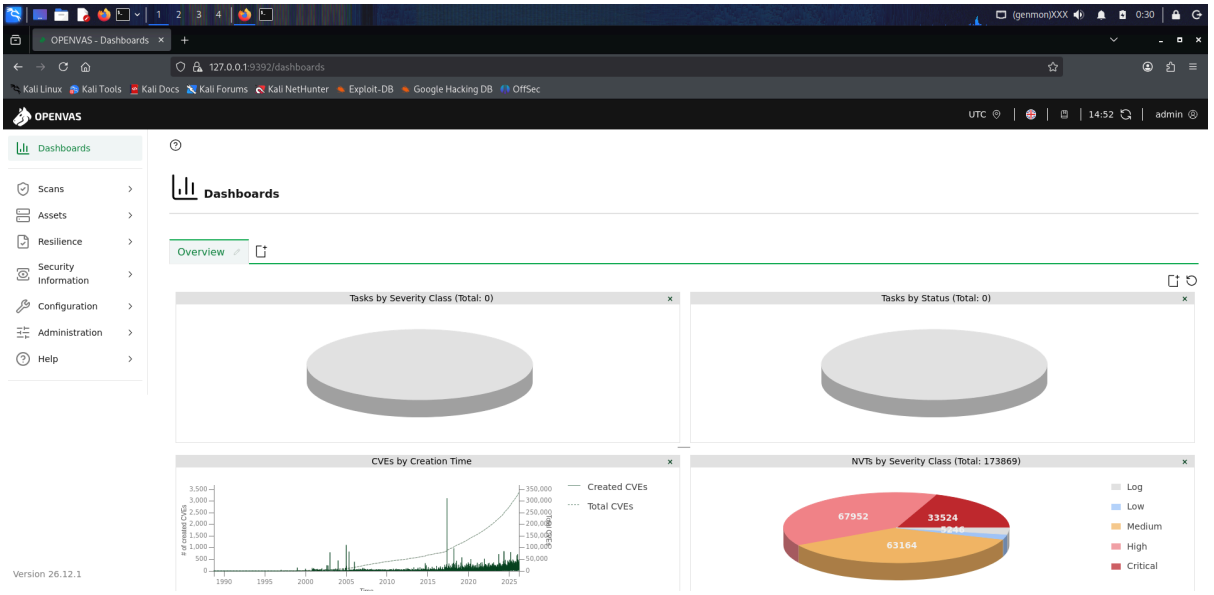
Port	Status	Service	Version
21/tcp	Open	ftp	Vstfpd 2.3.4
22/tcp	Open	ssh	OpenSSH 4.7p1 Debian 8ubuntu1
23/tcp	Open	telnet	Linux telnetd
25/tcp	Open	smtp	Postfix smtpd
53/tcp	Open	domain	ISC BIND 9.4.2
80/tcp	Open	http	Apache httpd 2.2.8
111/tcp	Open	rpcbind	2 (RPC #100000)
139/tcp	Open	Netbios-ssn Samba	Smbd 3.X - 4.X
445/tcp	Open	Netbios-ssn Samba	Smbd 3.0.20 - Debian
512/tcp	Open	exec?	-
513/tcp	Open	login	-
514/tcp	Open	tcpwrapped	-
1099/tcp	Open	java-rmi	GNU Classpath grmiregistry
1524/tcp	Open	bindshell	Metasploitable

			root shell
2049/tcp	**Open**	**nfs**	**2-4 (RPC #100003)**
2121/tcp	**Open**	**ftp**	**ProFTPD 1.3.1**
3306/tcp	**Open**	**mysql**	**MySQL 5.0.51a-3ubuntu5**
3632/tcp	**Open**	**distccd**	**Distccd V1**
5432/tcp	**Open**	**postgresql**	**PostgreSQL DB 8.3.0 - 8.3.7**
5900/tcp	**Open**	**vnc**	**VNC (Protocol 3.3)**
6000/tcp	**Open**	**x11**	**(access denied)**
6667/tcp	**Open**	**irc**	**UnrealIRCd**
6697/tcp	**Open**	**irc**	**UnrealIRCd**
8009/tcp	**Open**	**ajp13**	**Apache Jserv (Protocol v1.3)**
8180/tcp	**Open**	**http**	**Apache Tomcat/Coyote JSP engine 1.1**
8787/tcp	**Open**	**drb**	**Ruby DRb RMI (Ruby 1.8; path /usr/lib/ruby/1.8/drb)**
43547/tcp	**Open**	**status**	**1 (RPC #100024)**
45674/tcp	**Open**	**nlockmgr**	**1-4 (RPC**

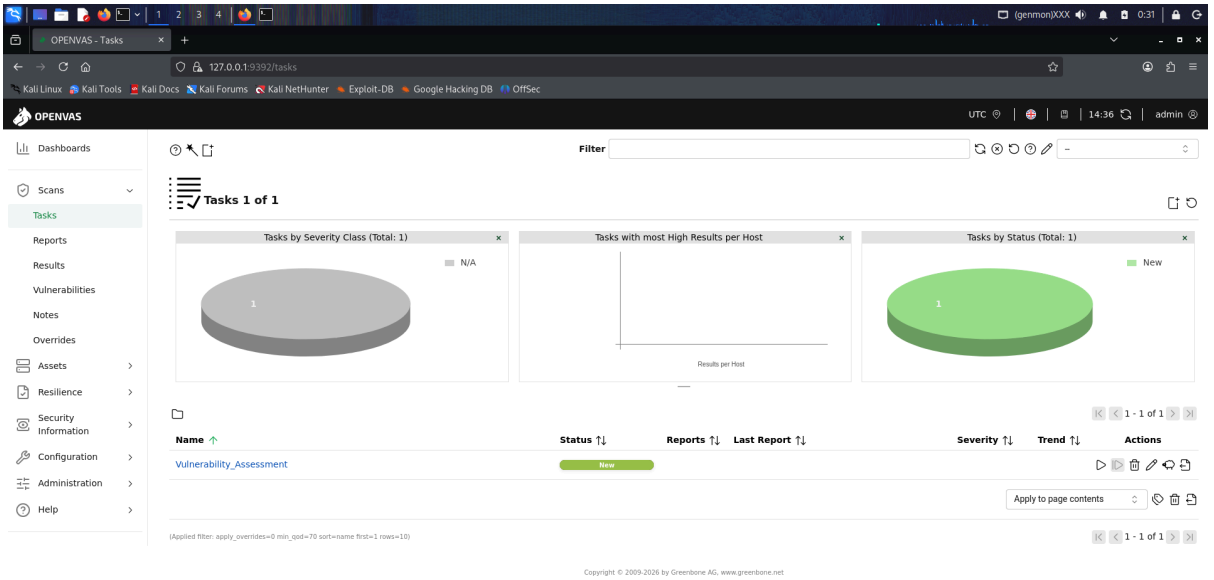
			#100021)
48263/tcp	**Open**	**java-rmi**	**GNU Classpath grmiregisty**
54383/tcp	**Open**	**mountd**	**1-3 (RPC #100005)**

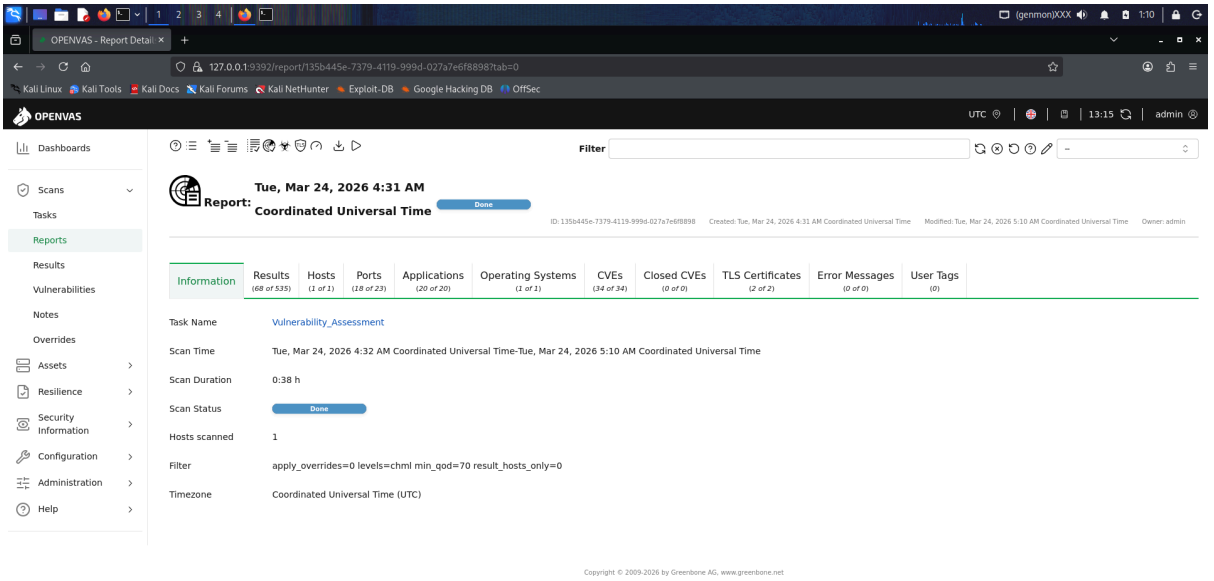
5. **The target system is highly vulnerable with multiple critical misconfigurations and outdated services. Some of the critical and highly vulnerable ports open and running on the target machine are 21, 23, 1524, 3306, 22, 25, 80, 445 and 8180.**
6. **To validate the findings and perform a deeper vulnerability assessment, OpenVAS will be used to scan the target:**





7. **Add the target and new scan task to initiate the scanning process of the Metasploitable machine. A report will be provided after the scan giving more information on the target system:**





8. **The report link is mentioned below:**

Vulnerability_Scan.pdf

9. **The following table shows the summarized output from OpenVAS:**

Vulnerability	Port	CVSS Score	Priority	Host
Rlogin passwordless login	513/tcp	10.0	Critical	192.168.31.242
Distributed Ruby	8787/tcp	10.0	Critical	192.168.31.242
vsftpd Compromised Source Packages Backdoor Vulnerability	21/tcp	9.8	Critical	192.168.31.242
TWiki < 4.2.4 Multiple XSS	80/tcp	10.0	Critical	192.168.31.242
PHP < 5.3.13, 5.4.x < 5.4.3 Multiple Vulnerabilities	80/tcp	9.8	Critical	192.168.31.242
DistCC RCE	3632/tcp	9.3	Critical	192.168.31.242

Vulnerability				
Operating System (OS) End of Life (EOL) Detection	general/ tcp	10.0	Critical	192.168.31.242
PostgreSQL Default Credentials	5432/tcp	9.0	Critical	192.168.31.242
vsftpd Compromised Source Packages Backdoor Vulnerability	6200/tcp	9.8	Critical	192.168.31.242
Apache Tomcat AJP RCE Vulnerability	8009/tcp	9.8	Critical	192.168.31.242
Possible Backdoor: Ingreslock	1524/tcp	10.0	Critical	192.168.31.242
VNC Brute Force Login	5900/tcp	9.0	Critical	192.168.31.242
rlogin service is running	513/tcp	7.5	High	192.168.31.242
FTP Brute Force Logins With Default Credentials Reporting	21/tcp	7.5	High	192.168.31.242
Java RMI Server Insecure Default Configuration RCE Vulnerability	1099/tcp	7.5	High	192.168.31.242
EasyPHP Webserver <= 12.1 Multiple Vulnerabilities	80/tcp	7.5	High	192.168.31.242
Test HTTP dangerous methods	80/tcp	7.5	High	192.168.31.242

UnrealIRCd Authentication Spoofing Vulnerability	**6697/tcp**	**8.1**	**High**	**192.168.31.242**
UnrealIRCd Backdoor	**6697/tcp**	**7.5**	**High**	**192.168.31.242**
FTP Brute Force Logins With Default Credentials Reporting	**2121/tcp**	**7.5**	**High**	**192.168.31.242**
SSL/TLS: OpenSSL CCS Man in the Middle Security Bypass Vulnerability	**5432/tcp**	**7.4**	**High**	**192.168.31.242**
rsh Unencrypted Cleartext Login	**514/tcp**	**7.5**	**High**	**192.168.31.242**
Anonymous FTP Login Reporting	**21/tcp**	**6.4**	**Medium**	**192.168.31.242**
FTP Unencrypted Cleartext Login	**21/tcp**	**4.8**	**Medium**	**192.168.31.242**
TWiki CSRF	**80/tcp**	**6.8**	**Medium**	**192.168.31.242**
TWiki < 6.1.0 XSS Vulnerability	**80/tcp**	**6.1**	**Medium**	**192.168.31.242**
jQuery < 1.9.0 XSS Vulnerability	**80/tcp**	**6.1**	**Medium**	**192.168.31.242**
TWiki CSRF Vulnerability	**80/tcp**	**6.0**	**Medium**	**192.168.31.242**
HTTP Debugging Methods (TRACE/TRACK)	**80/tcp**	**5.8**	**Medium**	**192.168.31.242**

Enabled				
phpinfo() Output Reporting (HTTP)	**80/tcp**	**5.3**	**Medium**	**192.168.31.242**
awiki <= 20100125 Multiple LFI Vulnerabilities	**80/tcp**	**5.0**	**Medium**	**192.168.31.242**
QWikiwiki directory traversal vulnerability	**80/tcp**	**5.0**	**Medium**	**192.168.31.242**
/doc directory browsable	**80/tcp**	**5.0**	**Medium**	**192.168.31.242**
Cleartext Transmission of Sensitive Information via HTTP	**80/tcp**	**4.8**	**Medium**	**192.168.31.242**
phpMyAdmin 'error.php' Cross Site Scripting Vulnerability	**80/tcp**	**4.3**	**Medium**	**192.168.31.242**
Apache HTTP Server 'httpOnly' Cookie Information Disclosure Vulnerability	**80/tcp**	**4.3**	**Medium**	**192.168.31.242**
jQuery < 1.6.3 XSS Vulnerability	**80/tcp**	**4.0**	**Medium**	**192.168.31.242**
FTP Unencrypted Cleartext Login	**2121/tcp**	**4.8**	**Medium**	**192.168.31.242**
Weak Host Key Algorithm(s) (SSH)	**22/tcp**	**5.3**	**Medium**	**192.168.31.242**
Weak Key Exchange (KEX) Algorithm(s)	**22/tcp**	**5.3**	**Medium**	**192.168.31.242**

Supported (SSH)				
Weak Encryption Algorithm(s) Supported (SSH)	**22/tcp**	**4.3**	**Medium**	**192.168.31.242**
SSL/TLS: Deprecated SSLv2 and SSLv3 Protocol Detection	**5432/tcp**	**5.9**	**Medium**	**192.168.31.242**
SSL/TLS: Report Weak Cipher Suites	**5432/tcp**	**5.9**	**Medium**	**192.168.31.242**
SSL/TLS: Server Certificate / Certificate in Chain with RSA keys less than 2048 bits	**5432/tcp**	**5.3**	**Medium**	**192.168.31.242**
SSL/TLS: Renegotiation DoS Vulnerability	**5432/tcp**	**5.0**	**Medium**	**192.168.31.242**
SSL/TLS: Certificate Expired	**5432/tcp**	**5.0**	**Medium**	**192.168.31.242**
SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	**5432/tcp**	**4.3**	**Medium**	**192.168.31.242**
SSL/TLS: Die-Hellman Key Exchange Insufficient DH Group Strength Vulnerability	**5432/tcp**	**4.0**	**Medium**	**192.168.31.242**
SSL/TLS: Certificate Signed Using A Weak Signature Algorithm	**5432/tcp**	**4.0**	**Medium**	**192.168.31.242**

Multiple Vendors STARTTLS Implementation Plaintext Arbitrary Command Injection Vulnerability	**25/tcp**	**6.8**	**Medium**	**192.168.31.242**
SSL/TLS: Deprecated SSLv2 and SSLv3 Protocol Detection	**25/tcp**	**5.9**	**Medium**	**192.168.31.242**
SSL/TLS: Server Certificate / Certificate in Chain with RSA keys less than 2048 bits	**25/tcp**	**5.3**	**Medium**	**192.168.31.242**
SSL/TLS: Renegotiation DoS Vulnerability	**25/tcp**	**5.0**	**Medium**	**192.168.31.242**
SSL/TLS: Certificate Expired	**25/tcp**	**5.0**	**Medium**	**192.168.31.242**
Check if Mailserver answer to VRFY and EXPN requests	**25/tcp**	**5.0**	**Medium**	**192.168.31.242**
SSL/TLS: RSA Temporary Key Handling 'RSA_EXPORT' Downgrade Issue	**25/tcp**	**4.3**	**Medium**	**192.168.31.242**
SSL/TLS: Deprecated TLSv1.0 and TLSv1.1 Protocol Detection	**25/tcp**	**4.3**	**Medium**	**192.168.31.242**

SSL/TLS: Certificate Signed Using A Weak Signature Algorithm	**25/tcp**	**4.0**	**Medium**	**192.168.31.242**
SSL/TLS: Die-Hellman Key Exchange Insufficient DH Group Strength Vulnerability	**25/tcp**	**4.0**	**Medium**	**192.168.31.242**
Telnet Unencrypted Cleartext Login	**23/tcp**	**4.8**	**Medium**	**192.168.31.242**
VNC Server Unencrypted Data Transmission	**5900/tcp**	**4.8**	**Medium**	**192.168.31.242**
Samba 3.0.0 <= 3.0.25rc3 MS-RPC Remote Shell Command Execution Vulnerability - Active Check	**445/tcp**	**6.0**	**Medium**	**192.168.31.242**

10. **The system is critically vulnerable with multiple remote code execution flaws, backdoors, and weak authentication mechanisms. An attacker can gain full system control with minimal effort.**
11. **To scan the vulnerabilities in the web server and application for the target, Nikto is used. Nikto allows to perform both authenticated and unauthenticated scans.**
12. **Authenticated scans refer to scanning a system using the credentials of the target machine to perform a full scan and unauthenticated scans refer to scanning systems on the surface level.**
13. **For the target 192.168.31.242, both scans provided the same result pointing there's no other content behind login:**

```
root@kali: /home/kali
Session  Actions  Edit  View  Help
└─# nikto -h 192.168.31.242 > web_scanning.txt

┌──(root㉿kali)-[/home/kali]
└─# cat web_scanning.txt
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.31.242
+ Target Hostname:    192.168.31.242
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-03-24 02:46:28 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php.
See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.det
ectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.dete
ctify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001386] /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.dete
ctify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001387] /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.dete
```

```
root@kali: /home/kali
Session  Actions  Edit  View  Help

┌──(root㉿kali)-[/home/kali]
└─# nikto -h 192.168.31.242 -id admin:4aa989d3-2759-432a-b69c-bb4b0a649046 > authenticated_scan.txt


┌──(root㉿kali)-[/home/kali]
└─# cat authenticated_scan.txt
- Nikto v2.6.0
---------------------------------------------------------------------------
+ Your Nikto installation is out of date.
+ Target IP:          192.168.31.242
+ Target Hostname:    192.168.31.242
+ Target Port:        80
+ Platform:           Unknown
+ Start Time:         2026-03-24 02:54:33 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ [999986] /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ [750500] /icons/: Directory indexing found.
+ No CGI Directories found (use '-C all' to force check all possible dirs). CGI tests skipped.
+ [600625] PHP/5.2.4-2ubuntu5.10 appears to be outdated (current is at least 8.5.1).
+ [600050] Apache/2.2.8 appears to be outdated (current is at least 2.4.66).
+ [999100] /index: Uncommon header(s) 'tcn' found, with contents: list.
+ [999965] /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php.
See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ [013587] /: Suggested security header missing: strict-transport-security. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security
+ [013587] /: Suggested security header missing: content-security-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP
+ [013587] /: Suggested security header missing: permissions-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy
+ [013587] /: Suggested security header missing: referrer-policy. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy
+ [013587] /: Suggested security header missing: x-content-type-options. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options
+ [999967] /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ [000434] /: HTTP TRACE method is active and replies which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ [750510] /phpinfo.php: Output from the phpinfo() function was found.
+ [750500] /doc/: Directory indexing found.
+ [001213] /doc/: The /doc/ directory is browsable. This may be /usr/doc. See: https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-1999-0678
+ [001384] /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP Easter Eggs reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.det
ectify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
+ [001385] /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP Easter Egg reveals potentially sensitive information via HTTP requests that contain specific QUERY strings. See: https://labs.dete
ctify.com/writeups/do-you-dare-to-show-your-php-easter-egg/
```

14. **The result for the output is as follow:**

    https://drive.google.com/file/d/1Of9SWVL6lhKAQ-lHdg9yVIv25AU6j_Rv/view?usp=drive_link

    https://drive.google.com/file/d/1HcmphYYpSQhyRK8AOgjQ9UmCskRvW3k1/view?usp=drive_link

15. **The web server is poorly configured and outdated, exposing sensitive information and multiple attack vectors. An attacker can easily gather information and exploit known vulnerabilities to compromise the system.**